BLOQUE C2

Autenticación local, eliminación de Supabase y pruebas HTTP completas

Informe técnico de ejecución del proyecto académico **Redes de Ayuda**. El recorrido administrador -> sesión verificada -> endpoint -> servicio -> repositorio CSV -> respuesta HTTP quedó probado sin infraestructura externa.

ESTADO	COMPLETO
Punto de partida	Commit 1e3b9e7f6f240cd88fd99ddcfa6ade7611848d0f (C1 preservado)
Entorno	Node.js 24.18.0 | npm 11.16.0 | Next.js 16.4.3 | Windows
Evidencia	14 unitarias + 25 CSV + 12 HTTP reales; lint, tipos, build y diff aprobados
Dependencias	Supabase retirado; no se añadió ninguna dependencia de autenticación

Alcance respetado: no se implementaron importación Excel, dashboard visual, simulación interactiva, portal de donantes, mapas, notificaciones ni módulos posteriores.

1. Resultado y arquitectura final

Se reemplazó Supabase Auth por un único administrador local. La contraseña se deriva con **scrypt** y sal aleatoria; la sesión usa un payload mínimo firmado con **HMAC-SHA256**, duración máxima de cuatro horas y validación en cada petición protegida.

LOGIN LOCAL	COOKIE FIRMADA	AUTORIZACION	SERVICIO	CSV/JSON
usuario + contraseña scrypt	HttpOnly SameSite=Lax expira	requireAdministrator() firma + exp + rol	caso de uso cálculos existentes	demo + runtime Zod

Componente	Decisión
Credenciales	ADMIN_USERNAME, ADMIN_PASSWORD_HASH y SESSION_SECRET; sin valores predeterminados ni valores reales versionados.
Contraseña	scrypt N=32.768, r=8, p=1, clave de 64 bytes, sal aleatoria de 16 bytes y comparación timing-safe.
Sesión	Payload v1 con sujeto, rol, emisión y expiración; firma y payload base64url canónicos; HMAC-SHA256.
Cookie	redes_ayuda_session; HttpOnly, SameSite=Lax, Path=/, Expires/Max-Age y Secure bajo HTTPS.
CSRF	POST de login y logout exigen Origin exacto respecto del Host/protocolo efectivo.
Autorización	Anónimo o token inválido: 401. Sesión válida no admin: 403. Administrador válido: 200.

2. Inventario de archivos

Cada ruta modificada, creada o retirada durante C2 se registra a continuación.

Ruta	Estado	Responsabilidad	Lógica del cambio
.env.example	Modificado	Configuración	Deja vacías las tres variables locales; no versiona credenciales conocidas.
README.md	Modificado	Operación	Instalación, configuración, hash, secreto, login/logout, API, pruebas y limitación stateless.
docs/API.md	Modificado	Contrato HTTP	Documenta login/logout/me, cookies, Origin y códigos de autenticación.
docs/ARQUITECTURA.md	Modificado	Arquitectura	Describe sesión firmada y flujo hacia repositorio CSV sin servicio externo.
docs/BITACORA.md	Modificado	Historial	Añade secuencia C2 y evidencia, preservando B y C1.
docs/DATOS.md	Modificado	Datos	Aclara que el seed SQL es historia recuperable y que las credenciales no viven en CSV.
docs/DECISIONES.md	Modificado	Decisiones	Registra scrypt, HMAC, TTL, cookie, Origin y retirada posterior a pruebas.
docs/ESTADO.md	Modificado	Estado	Clasifica C2 como completo con evidencia final.
docs/PRUEBAS_C2.md	Creado	Evidencia	Matriz T01-T14, comandos, reproducibilidad y limitaciones.
package.json	Modificado	Scripts/deps	Añade auth:hash y elimina scripts/dependencias Supabase.
package-lock.json	Modificado	Reproducibilidad	Lockfile regenerado sin paquetes Supabase.
scripts/generate-admin-password-hash.mjs	Creado	Herramienta local	Solicita contraseña dos veces sin eco ni argumento y emite sólo hash scrypt.
src/app/api/auth/login/route.ts	Creado	Login	Valida Origin/body, compara de forma segura y emite cookie administrativa.
src/app/api/auth/logout/route.ts	Creado	Logout	Valida Origin y elimina la cookie con Max-Age=0.
src/app/api/auth/me/route.ts	Creado	Sesión	Informa estado y usuario sin revelar secretos.
src/app/login/page.tsx	Modificado	Interfaz mínima	Usa endpoints locales para entrar, consultar sesión y salir; sin localStorage.
src/server/auth/config.ts	Creado	Configuración segura	Lee configuración perezosa, sin defaults, y falla cerrada.
src/server/auth/password.ts	Creado	Contraseñas	Generación/verificación scrypt, formato estricto y comparaciones timing-safe.
src/server/auth/session.ts	Creado	Sesiones	Firma/verifica token, TTL, canonicalización, cookie HTTPS y Origin.
src/server/auth/require-admin.ts	Modificado	Autorización	Sustituye Supabase por cookie local; conserva el control central 401/403.
src/server/repositories/operations.ts	Modificado	Aislamiento de pruebas	Permite raíces CSV del proceso hijo sin reescribir el repositorio.
tests/http/endpoints.test.ts	Modificado	HTTP real	12 casos con servidor Next, credenciales efímeras y copias CSV temporales.
tests/unit/auth.test.ts	Creado	Seguridad pura	6 pruebas adicionales de hash, firma, expiración, canonicalización, cookie y Origin.
src/lib/supabase-browser.ts	Retirado	Cliente navegador	Ya no se necesita cliente externo.
src/proxy.ts	Retirado	Proxy	Ya no se refrescan sesiones externas; cada handler verifica la firma.

Ruta	Estado	Responsabilidad	Lógica del cambio
src/server/auth/update-session.ts	Retirado	Sesión antigua	Elimina renovación de cookie Supabase.
src/server/db/env.ts	Retirado	Entorno antiguo	Elimina variables públicas Supabase.
src/server/db/supabase-server.ts	Retirado	Cliente servidor	Elimina cliente SSR Supabase.
tests/helpers/supabase.ts	Retirado	Fixture antigua	Las pruebas ya generan credenciales y tokens locales.
tests/integration/authorization.test.ts	Retirado	Suite obsoleta	Sustituida por autorización HTTP local real.
tests/integration/database.test.ts	Retirado	Suite obsoleta	La persistencia activa es CSV y ya tiene 25 pruebas.
supabase/.gitignore	Retirado	Legado activo	Árbol Supabase fuera de la aplicación; recuperable en Git.
supabase/config.toml	Retirado	Legado activo	Elimina configuración CLI/Docker.
supabase/migrations/20261023170000_initial_schema.sql	Retirado	Legado activo	Migración preservada en checkpoints Git.
supabase/seed.sql	Retirado	Legado activo	Seed preservado en Git; los CSV demo siguen intactos.

3. Matriz de pruebas T01-T14

Prueba	Esperado	Obtenido	Estado
T01	Login correcto + cookie segura	200; HttpOnly, SameSite=Lax, Path, Expires/Max-Age; Secure probado en HTTPS; /me admin	APROBADA
T02	Credenciales incorrectas	401 INVALID_CREDENTIALS, mensaje genérico, sin Set-Cookie	APROBADA
T03	Sesión anónima	GET /api/snapshots -> 401 UNAUTHENTICATED	APROBADA
T04	Sesión sin privilegios	Fixture firmada viewer -> 403 FORBIDDEN; sin ruta productiva de emisión	APROBADA
T05	Administrador autorizado	200; lista de 2 snapshots y detalle correcto por id	APROBADA
T06	Consultas CSV reales	200; 6 centros, 5 productos, 7 presentaciones y tiempos dirigidos	APROBADA
T07	Dashboard consistente	12.000 inventario; 20.000 objetivo; 8.000 déficit; 6.000 anunciados	APROBADA
T08	Aislamiento	C01/P01: snapshot A 12.000; snapshot B 2.700	APROBADA
T09	Seguridad de sesión	Alteración, firma/codificación inválida, expirada, otra clave, ausente y post-logout -> 401	APROBADA
T10	Errores HTTP	400 ausente; 400 UUID; 404 inexistente; 500 CSV corrupto sin filtraciones	APROBADA
T11	Regresión	14/14 unitarias (incluye 8 previas) y 25/25 CSV	APROBADA
T12	Verificaciones	Lint, typecheck, build y git diff --check correctos	APROBADA
T13	Independencia	Sin Docker/PostgreSQL/cuenta/variables/paquetes Supabase; lectura CSV	APROBADA
T14	Reproducibilidad	npm ci; servidor real; login; 2 snapshots; 6 centros; batería completa	APROBADA

Evidencia agregada

La evidencia se obtuvo sobre el árbol final, después de retirar Supabase y ejecutar una instalación limpia. Ninguna prueba omitida se contabilizó como aprobada.

Comando	Resultado
npm ci	Exitoso; 377 paquetes instalados desde el lockfile final.
npm ls @supabase/ssr @supabase/supabase-js supabase --all	Árbol vacío.
npm run test:unit	4 archivos; 14 pruebas aprobadas.
npm run test:csv	3 archivos; 25 pruebas aprobadas.
npm run test:http	1 archivo; 12 pruebas HTTP reales aprobadas.
npm run test:integration	3 archivos; 25 pruebas de integración CSV aprobadas.
npm run lint / npm run typecheck	Sin errores.
npm run build	Compilación aprobada; 13 páginas/rutas.
git diff --check	Sin errores; sólo advertencias informativas de fin de línea en Windows.

Aspecto	Control de evidencia
HTTP	Servidor Next real en puerto efímero; login, siete GET existentes y logout; sin mock de repositorio.
Datos	Copia temporal de ambos snapshots. El caso 500 corrompe sólo esa copia y se elimina al terminar.
Seguridad	Credenciales, hash y secreto aleatorios del proceso hijo; no aparecen en salida ni documentación.
Revisión	Se corrigieron secreto de ejemplo, base64url no canónico y cobertura de endpoints; revisión final sin bloqueantes.

Nota del entorno: el primer build dentro del sandbox recibió EPERM al escribir .next. El mismo build, ejecutado con permisos normales de Windows, compiló las 13 páginas/rutas. No es una dependencia ni un fallo del proyecto.

4. Operación local

Variables requeridas

```
ADMIN_USERNAME=
ADMIN_PASSWORD_HASH=
SESSION_SECRET=
```

Los valores se dejan vacíos en **.env.example**. No existen credenciales ni secretos conocidos que permitan arrancar o firmar sesiones por accidente.

Generar el hash de contraseña

```
npm run auth:hash
```

El comando exige terminal interactiva, solicita confirmación sin eco y rechaza contraseñas entregadas como argumento. Copiar sólo el hash resultante a ADMIN_PASSWORD_HASH.

Generar un secreto de sesión

```
node -e "process.stdout.write(require('node:crypto').randomBytes(48).toString('base64url') + '\\n')"
```

Inicio y recorrido manual

Paso	Acción
1	Copiar .env.example a .env.local y completar las tres variables.
2	Ejecutar npm run dev y abrir http://localhost:3000/login.
3	Ingresar ADMIN_USERNAME y la contraseña original; el navegador recibe la cookie HttpOnly.
4	Consumir GET /api/snapshots o cualquiera de los seis endpoints operativos restantes.
5	Cerrar sesión desde /login o POST /api/auth/logout con Origin del mismo sitio.

Ejecutar pruebas

```
npm run test:unit
npm run test:csv
npm run test:http
npm run lint
npm run typecheck
npm run build
```

5. Seguridad, limitaciones y estado del repositorio

Control	Resultado
Fail closed	Configuración ausente o inválida nunca concede acceso; sesiones ausentes o inválidas reciben 401.
Roles	Login productivo sólo emite admin. El 403 usa una fixture firmada aislada de pruebas.
Manipulación	Firma, payload, base64url no canónico, expiración, vida máxima y clave se validan en cada petición.
CSRF	Login/logout rechazan Origin ausente o de otro sitio.
Datos	La suite HTTP corrompe sólo una copia temporal; no modifica demo ni runtime personal.
Revocación	Logout borra la cookie del cliente. Un token copiado sigue válido hasta expirar; rotar SESSION_SECRET invalida todos.

Dependencias

Retiradas: @supabase/ssr, @supabase/supabase-js y supabase CLI.
Añadidas: ninguna. La autenticación usa únicamente primitivas de node:crypto.

Estado Git al entregar

Campo	Valor
Rama	codex/c1-csv-persistence
HEAD de partida	1e3b9e7f6f240cd88fd99ddcfa6ade7611848d0f
Commit/push C2	No realizados, por instrucción.
Cambios	Presentes en el árbol de trabajo para revisión humana.
Checkpoint C1	Preservado y recuperable en Git.
Siguiente acción	Revisar C2; no iniciar módulos posteriores sin aprobación.

CONCLUSION **C2 COMPLETO Y LISTO PARA REVISION**